

(c) Narrativa explicativa del marco QGM + PRAGMATIC aplicado a MITRE

D3FEND

Hay dos formas de coleccionar métricas: como quien colecciona imanes de nevera o como quien construye un mapa de navegación. Este documento intenta, modestamente, empujar hacia lo segundo.

1. De los objetivos grandilocuentes a las preguntas incómodas

Las estrategias nacionales de ciberseguridad están llenas de objetivos loables: “reforzar la resiliencia”, “mejorar la capacidad de respuesta”, “proteger las infraestructuras críticas”.^{[web:17][web:20][web:23]} Lo complicado es traducir esos enunciados a preguntas que alguien en un SOC, en un operador OT o en un comité de dirección pueda contestar sin recurrir sólo a adverbios.

QGM parte de una idea simple y razonable: antes de medir nada, formulemos el objetivo; después, preguntemos qué deberíamos saber para juzgar si lo estamos logrando; sólo entonces definamos las métricas.^{[web:18][web:21]} Colocar a D3FEND en medio de este esquema permite expresar los objetivos en lenguaje de amenazas y contramedidas, y las preguntas en términos de coberturas, latencias, telemetría y eficacia.^{[web:3][web:5]}

2. D3FEND como puente entre estrategia y consola

D3FEND aporta algo que los PowerPoints rara vez consiguen: una estructura formal para describir qué controles tenemos, dónde actúan, sobre qué artefactos y frente a qué técnicas.^{[web:1][web:19]} Cuando un objetivo nacional habla de “mejorar la capacidad de detección”, podemos preguntar, en clave ATT&CK–D3FEND, cuántas técnicas críticas tienen una detección razonable y cuántas siguen en tierra de nadie.^{[web:3][web:5][web:8]}

Las métricas de cobertura ATT&CK–D3FEND (M1.x) y de telemetría (M4.x) son la traducción cuantitativa de esa conversación. No son perfectas, pero permiten decir algo más concreto que “hemos desplegado muchas soluciones”.^{[web:5][web:18]}

3. PRAGMATIC: el antídoto contra la métrica inútil

Una vez desatada la pasión por medir, aparece un peligro diferente: el síndrome del dashboard ornamental. Aquí entra PRAGMATIC: un conjunto de criterios que obliga a preguntarse si una métrica predice algo, es relevante para los objetivos, sugiere acciones claras, refleja la realidad, se entiende, es precisa, llega a tiempo, no induce perversiones y merece el coste de medirla.

Aplicar PRAGMATIC a métricas como el MTDD (M2.1) o el porcentaje de técnicas críticas sin contramedidas (M1.3) revela por qué son tan valiosas: no sólo cuentan historias del pasado, sino que señalan dónde invertir el siguiente euro.^{[web:18][web:21]} En cambio, otras métricas más sofisticadas, como el indicador compuesto de calidad de telemetría (M4.3), exigen más trabajo para definirlas y explicarlas.^{[web:1][web:19]}

4. OT, donde el tiempo y la física no perdonan

En entornos OT, la combinación GQM + PRAGMATIC se vuelve casi cuestión de supervivencia. Los objetivos (G5) hablan de mantener servicios esenciales, las preguntas se centran en rutas de mando y control y tiempos de recuperación, y las métricas (M5.x) se convierten en una forma de expresar en números qué parte de la infraestructura puede permitirse un susto sin que el país lo note.[web:5][web:20]

PRAGMATIC ayuda a priorizar: es mejor medir bien el porcentaje de rutas OT con controles y monitorización (M5.1) y el MTTR-OT (M5.3) que dispersarse en indicadores poco accionables que nadie discutirá en el comité de crisis.

5. De la consola al BOE (y vuelta)

La gracia de este marco es que la dirección de la trazabilidad es bidireccional. Desde arriba hacia abajo, un regulador puede decir: “queremos que, en cinco años, ningún operador esencial tenga más del X % de técnicas críticas sin contramedidas” y traducirlo en requerimientos de reporte basados en M1.1–M1.3.[web:25][web:26][web:27]

Desde abajo hacia arriba, un CISO puede utilizar las mismas métricas para justificar inversiones, demostrar progresos y, sobre todo, explicar por qué un IGM alto no es un adorno, sino el resultado de coberturas reales, tiempos razonables y telemetría decente.[web:5][web:18][web:21]

6. Lo que este marco no hace (y no debe hacer)

El marco no pretende homogeneizar la realidad diversa de sectores, tecnologías y culturas organizativas. Un indicador sensato en un banco puede ser irrelevante en una empresa de agua, y viceversa. Tampoco sustituye el criterio experto: la ponderación de métricas y la fijación de objetivos seguirá siendo, en buena parte, un arte informado más que una ciencia exacta.

Lo que sí hace es ofrecer un lenguaje común para debatir sobre métricas sin caer en la trampa de confundir actividad con progreso. Si una métrica no pasa el filtro PRAGMATIC, quizá merezca un lugar en un informe técnico, pero no en el cuadro de mando que se discute en una mesa donde se reparte presupuesto.

7. Epílogo: medir con intención

El reto no es sólo medir más, sino medir con intención. Intención de aprender, de ajustar, de priorizar y, a veces, de reconocer límites. GQM pone orden a la hora de definir qué tiene sentido medir; PRAGMATIC ayuda a descartar lo que sólo engorda hojas de cálculo.

Si este marco consigue que, en una próxima revisión de estrategia, alguien pregunte “¿qué técnicas concretas del adversario tenemos cubiertas y cuáles no, y cómo lo sabemos?”, habrá cumplido de sobra su misión.